

Programme étudiant — 20 septembre 2026

Objectifs du jour

À la fin de la journée, vous saurez borner un test autorisé, suivre une requête, lire les contrôles HTTP/navigateur, construire un modèle de menace, observer le cycle de session et prouver une décision d'autorisation objet avec les statuts 200/401/403.

Tous les tests restent sur 127.0.0.1 ou le réseau Docker ShopLab autorisé. N'utilisez jamais ces commandes sur un système tiers.

Dépôt et supports

```
git clone https://github.com/jodouma/leaders-web-security-labs.git
cd leaders-web-security-labs
git pull --ff-only
./scripts/verify-host.sh
```

- Cours : [course-materials/course/cours_complet.pdf](#)
- Présentation du jour : [course-materials/presentations/2026-09-20_S01-S08.pdf](#)
- TD : [course-materials/td-guides/](#)
- TP : [course-materials/tp-guides/](#)
- Lab : [labs/shoplab/](#)
- Dépannage : [course-materials/lab-guides/depannage.pdf](#)

Matin — 08:30–11:45

S01 Éthique/scope/preuve → S02 chemin d'une requête → S03 HTTP/navigateur → **TP01 sélection essentielle** → **TD01 compact** → validation [basic](#).

Checklist : dépôt à jour; Docker actif; [verify-host.sh](#) sans **FAIL**; créer un dossier [preuves/](#) non suivi par Git; ne jamais enregistrer token/cookie.

Après-midi — 12:30–15:45

S04 modèle de menace → **TD02 compact** → S05 authentication/session → **TP02 sélection essentielle** → S06 autorisation/BOLA → **TP03 sélection essentielle** → validation [authz](#).

Si le groupe a 15–30 minutes d'avance : S07 validation/SQLi → S08 XSS/CSRF/CSP → **TP04-A**.

Démarrer ShopLab

```
cd labs/shoplab
./scripts/lab-start.sh core
./scripts/health-check.sh core
```

Attendu : services core actifs, HTTP 200, `mode=vulnerable`. En fin de journée :

```
./scripts/reset.sh
./scripts/cleanup.sh
```

Preuves à conserver

- trace HTTP/TLS et scope TP01;
- notes TD01;
- DFD et deux scénarios TD02;
- chronologie et statuts TP02, sans valeurs sensibles;
- matrice 200/401/403 et tests TP03;
- option Lightning : résultat SQLi avant/après TP04;
- synthèse : « appris / prouvé / prochaine question ».

En cas de problème

Lisez [course-materials/lab-guides/depannage.pdf](#). Un [FAIL] hôte bloque le lab de votre poste : travaillez en binôme et signalez la ligne exacte. Masquez toute donnée personnelle, token, cookie ou mot de passe avant de partager une capture.